题目二　网络安全威胁情报知识图谱（CVE × CWE × CPE × ATT&CK）

课程：知识图谱技术与应用（网络工程）　**组员/学号**：_____

日期：2026-10-21　**仓库链接**：https://github.com/sxy-Cindy/network-kg-t2

一条命令：scripts\run_t2.cmd（Windows；Linux/macOS 见 §7）

摘要

本作业以 40 条公开 CVE 为切片，打通 **CVE → CWE → CAPEC → ATT&CK** 与 **CVE → CPE → 厂商**、**CVE → KEV** 五条跨源链路，构建了 421 节点 / 1572 边的威胁情报知识图谱。本体含 **19 个类、17 个关系**，每个类与关系都标注了官方来源与建模理由，自检 0 问题。三种抽取方法在同一语料、同一本体、同一评测协议下对比：

方法	实体 P / R / F1	三元组 P / R / F1
A 规则/词典 + 官方字段映射	0.9653 / 1.0000 / 0.9823	0.9924 / 0.9962 / 0.9943
B 序列标注 + 关系分类	0.9549 / 0.8715 / 0.9113	0.9694 / 0.4859 / 0.6474
C LLM 受本体约束抽取	0.8482 / 0.9769 / 0.9080	0.8560 / 0.9808 / 0.9142
融合（投票 + 置信度）	0.9581 / 1.0000 / 0.9786	0.9572 / 1.0000 / 0.9781

融合后 1/2/3 票三元组分别为 788/402/382 条，2 票与 3 票的精确率分别为 **100%** 与 **99.21%**。阶段三 Agent 在 12 道题（4 道多跳、2 道应拒答）上检索覆盖 27/27、答案覆盖 27/27、拒答 2/2；图谱增强答案的不可溯源句为 **0/19**，无图谱基线为 **7/12（58.33%）**；LLM 单方法图与融合图的幻觉率同为 **0%**（详见 §6.2.1）。跨源 ID 映射逐类给出召回/精确率与固定种子抽样，CISA KEV 在本切片 40 条 CVE 上覆盖 40/40。

1　选题与目标

题目二要求把漏洞、弱点、受影响产品、攻击技术与在野利用记录连成一张可查询、可溯源的图，支撑两类问题：

1. **暴露面**：某型号/版本的产品受哪些漏洞影响？根因是什么？是否已被在野利用？
2. **检测覆盖**：某攻击技术由哪些 Sigma 规则覆盖？它属于哪个战术？攻击组织是否使用？

三个阶段的交付物：

阶段	交付物	本作业结果
1	本体（OWL/RDFS）	19 类 / 17 关系；TTL 325 三元组；自检 0 问题
2	三方法抽取 + 融合/消歧/质量门槛	406 实体 / 1572 三元组；GraphML/Cytoscape 导出
3	KG 增强 Agent + 幻觉率 + 三级溯源	12 题；检索/答案覆盖 100%；幻觉率 0

范围控制：按作业要求不导入 31M 三元组的全量 security-kg，只取 40 条 CVE 及其关联的 CWE/CAPEC/ATT&CK/Sigma 切片；每个 CVE 的 CPE 按 vendor/product/主次版本去重后最多保留 4 条，避免补丁版本刷屏。

2　数据源与合规声明

2.1 逐源清单与许可证

数据源	用途	许可证 / 条款	许可代码
NVD CVE API 2.0 + CVE Services API 2.1	CVE 描述、CWE、CPE 配置、CVSS、参考链接	美国政府公开数据；CVE 记录遵循 CVE Program Terms of Use	public-domain
CISA KEV Catalog	在野利用记录、厂商/产品、收录与整改日期	美国政府公开数据（public domain）	public-domain

数据源	用途	许可证 / 条款	许可代码
MITRE ATT&CK Enterprise（STIX 2.x）	技术/战术/组织/软件/缓解及其关系	CC BY 4.0	CC-BY-4.0
MITRE CWE 4.20（XML）	弱点名称、描述、Related_Attack_Patterns	MITRE CWE Terms of Use（免费使用，需署名）	mitre-terms
MITRE CAPEC 3.9（XML）	攻击模式名称、描述、关联弱点	MITRE CAPEC Terms of Use（免费使用，需署名）	mitre-terms
SigmaHQ Sigma	检测规则编号、标题、标签、等级（**仅元数据**）	Detection Rule License (DRL) 1.1	DRL-1.1
FIRST EPSS API	漏洞利用概率分数与百分位	CC BY 4.0	CC-BY-4.0

逐文档到来源/许可证的映射保存在 topics/t2-cve-attack/sources.yaml，阶段三的第三级溯源直接读取该文件。

2.2 三道数据红线

1. **只使用公开、可再分发的数据**。本作业没有 GB/T 标准全文、没有实验室设备配置、没有自采日志；Sigma 只保留规则元数据（UUID/标题/标签/描述），不复制检测逻辑。
2. **原始数据不入库**。data/raw/ 与 data/llm_cache/ 已写入 .gitignore，由 scripts/fetch_t2_data.py 重新下载；仓库只保留可公开的派生语料与产物。
3. **合规声明与门禁**。提交前运行 tools/check_restricted_data.py，当前结果：**高风险 0 项，中/低风险 0 项，通过**。

2.3 合规声明（正文）

> 本组声明：本作业仅使用上表所列公开数据源，未使用任何需登录、付费或授权的内容；未上传国家标准全文、实验室设备配置、自采日志或任何含真实凭据的材料；数据切片与派生语料仅用于课程作业，不用于商业分发。Sigma 规则仅使用元数据，符合 DRL 1.1；ATT&CK、CWE、CAPEC、EPSS 的使用遵守各自署名要求。
> 组员签名：_____ 日期：_____

3 阶段一：本体设计

3.1 设计方法

采用 Noy & McGuinness 七步法，但**类与关系的取舍由官方字段决定**，而不是凭直觉罗列：凡是跨源映射需要的实体（CVE/CWE/CAPEC/CPE/KEV/ATT&CK），都能在数据源里找到稳定的官方编号，才建类；名称只做 rdfs:label 或别名，避免版本更名导致主键漂移。

- 命名空间：http://kgcourse.org/ontology/threat-intel#
- 主键策略：官方编号即主键（CVE-…、CWE-…、CAPEC-…、T1059.001、TA0002、G0096、S####、M####、cpe:2.3:…）；KEV 记录无独立编号，主键由所属 CVE 派生为 kev:CVE-…，标签固定为 KEV entry for CVE-…。
- 子技术关系方向固定为“子技术 → 父技术”（subtechnique_of），与 ATT&CK STIX 一致。

3.2 类与关系

19 个类：SecurityConcept（顶层）、Document、Vulnerability、Weakness、 AttackPattern、Product、Vendor、Technique、Tactic、Group、Campaign、 Software（含 Malware、Tool 子类）、Mitigation、DetectionRule、ExploitationRecord、Exploit、Advisory。

17 个关系：has_weakness、affects_product、produced_by、known_exploited、 announced_in、relates_to_pattern、implemented_by、belongs_to_tactic、 subtechnique_of、uses、group_uses、software_uses、campaign_uses、used_by、mitigates、detects、mentioned_in。

每个类、每个关系在 topics/t2-cve-attack/ontology.json 中都有 source（官方依据）与 rationale（为什么这样建模）；TTL 中用 rdfs:isDefinedBy 与 skos:scopeNote 输出，便于答辩时逐条核对。例如：

- has_weakness ← NVD weaknesses[] / CVE problemTypes；理由：根因是官方字段，不需要从正文推断。

- implemented_by ← 24 条分析师 crosswalk；理由：MITRE 没有官方 CAPEC→ATT&CK 映射，必须显式人工映射并标注 confidence，不能伪装成官方标准。
- mentioned_in ← 本作业的溯源结构；理由：连接实体与来源文档，不参与知识推理，路径查询默认排除文档节点。

3.3 自检

python -m kgc.ontology --topic t2-cve-attack --check 结果： {"ok": true, "problems": [], "class_count": 19, "relation_count": 17}； TTL 可被 rdflib 以 Turtle 解析（325 三元组）。检查项包括命名空间、类/关系定义、 domain/range 指向已定义类、标签非空、无重复 ID。

4 阶段二：三种抽取方法与融合

4.1 统一语料与评测口径

15 篇文档、约 173 KB：4 篇 CVE 记录、KEV 切片、ATT&CK 技术/战术/组织/软件/缓解、CWE、CAPEC、CAPEC 交叉映射表、Sigma 规则元数据、EPSS。三种方法读同一份语料、同一份本体、同一份 patterns.yaml/词典配置；方法 C 按文档分块（71 块）。

金标准由 scripts/build_gold.py 从**官方结构化字段全量**构造（389 实体 /782 关系），不 import 任何抽取方法，保留“标签在语料中字面出现且头尾同文档”的可核对子集。方法 A 的结构化通道读的是同一批字段，因此 A 的高分是**数据通道优势**，不是抽取能力的证据；B/C 只能从渲染文本抽，三者对比才有意义。表中 precision 是下界：正文抽出的、官方字段没有的正确知识仍会被记为误报。

4.2 方法 A：规则/词典 + 结构化映射

- 正则/词典：官方编号 + 人工触发词 + 句内共现，产出 713 实体 / 1103 关系；
- 结构化映射：NVD configurations 的 CPE、problemTypes 的 CWE、KEV 的 cveID、ATT&CK STIX 的 kill_chain_phases/uses/mitigates、CWE Related_Attack_Patterns、 Sigma attack.tXXXX 标签，产出 652 实体 / 1482 关系；
- 合并去重后 **755 实体 / 1540 关系**，0 个实体缺溯源。

单独跑纯正则（kgc.rule，713/1103）作为消融，用来量化结构化映射的贡献：三元组从 1103 增至 1540，主要是 produced_by、known_exploited、affects_product 这些“正文里没有独立文字表述”的关系。

4.3 方法 B：序列标注 + 关系分类

- 实体：字符级 token + BIO 标注，sklearn LogisticRegression；
- 关系：在实体对之间抽特征（距离、触发词、类型组合、上下文词），单独训练多分类器；
- **文档级 5 折交叉验证**：同一文档不跨折，避免同篇文本泄漏；最终模型在全量语料上重训后产出图谱。结果为 **692 实体 / 392 关系**。
- 指标：实体 P 0.9549 / R 0.8715 / F1 0.9113；三元组 P 0.9694 / R **0.4859**。

关系召回明显低，原因是 produced_by、known_exploited 等关系在语料里以结构化串或标签形式出现，没有自然语言触发句，序列标注+句内关系分类学不到。这是方法 B 的**结构性缺口**，不是调参能解决的；报告如实保留。

4.4 方法 C：LLM 受本体约束抽取

- Prompt 显式给出本体类/关系清单、官方 ID 规则、输出 JSON schema；
- 要求每条关系给出 evidence（原文连续片段）与实体 ref（块内编号）；
- 解析后做四道校验：JSON 可解析、类/关系在本体内、ref 可解析、证据是原文子串；
- 结果：71 块 → **801 实体 / 985 关系**；JSON 解析错误 0、越界类 0、坏引用 0、缺证据 0；证据校验通过 **980/985（99.5%）**，5 条关系因证据不是连续原文被降级。
- 证据无法通过校验的条目不会静默删除，而是记录在 rejected 与 entity_unverified/relation_unverified 计数中，便于人工复核。

4.5 融合、消歧与质量门槛

融合算法（kgc/fuse.py）：

1. **ID 归一优先于标签对齐**：先按官方编号把 “The KEV entry for CVE-x” 与 “KEV entry for CVE-x” 收敛为同一主键 kev:CVE-x，再做 (type, label) 对齐；
2. **三元组投票**：以 (头, 关系, 尾) 为键收集命中方法，置信度 = Σ 命中方法权重 / Σ 全部方法权重（rule 1.0 / model 0.8 / llm 1.3）；
3. **质量门槛**：标签不合法、受控词表外、非官方编号三类实体丢弃；
4. **域值域校验**：违规边记入报告并降权 0.5，不静默删除。

本次融合结果：**406 实体 / 1572 三元组**；投票分布 1 票 788、2 票 402、3 票 382。质量门槛丢弃 **44** 个实体：自由文本 Product 33 个（如 “SMBv1” “FortiOS”，没有 CPE 主键）、弱点名称 10 个（如 “use-after-free”，不是 CWE 节点）、攻击模式名称 1 个；标签不合法 0、受控词表外 0、域值域违规 0。

> 为什么丢弃自由文本 Product：保留会与 CPE 节点形成两个“同一产品”，污染对齐和问答；这是精度优先的显式取舍，丢弃清单全部留在 *_ensemble.json 中可复核。

4.6 评测与投票分析

方法	实体 P	实体 R	实体 F1	三元组 P	三元组 R	三元组 F1
A 规则/词典 + 结构化	0.9653	1.0000	0.9823	0.9924	0.9962	0.9943
B 模型	0.9549	0.8715	0.9113	0.9694	0.4859	0.6474
C LLM	0.8482	0.9769	0.9080	0.8560	0.9808	0.9142
融合	0.9581	1.0000	0.9786	0.9572	1.0000	0.9781

融合按票数拆分：

命中方法数	三元组数	精确率（下界）	召回	F1
1 票	33	0.0303	0.0013	0.0025
2 票	402	**1.0000**	0.5141	0.6791
3 票	382	**0.9921**	0.4847	0.6512

解读：2 票与 3 票的精确率接近 100%，说明“多方法一致”是可靠的可信度信号，下游 Agent 可以用 min_confidence 过滤；1 票三元组几乎全是 LLM 从正文抽出的额外知识（官方字段里没有），精确率低但不应简单视为幻觉——它们是**召回扩展**，报告按“下界”解释。融合的实体/三元组召回均为 1.0，是因为它的并集覆盖了结构化通道导入的全部官方映射；这也是 A 的数据通道优势，不应解读为“融合比官方字段更准”。

5 跨源 ID 映射核验与 KEV 覆盖

scripts/cross_source_report.py 不数“图里有多少边”，而是拿官方结构化字段当参照，逐类计算召回/精确率，并用固定种子 20261021 每类抽 8 条供人工复核。分母只统计**头、尾实体都已进入图谱**的官方映射：未导入的实体（例如未选入的 CAPEC）不算漏抽。

映射	关系	参照	官方映射	图谱边	命中	Recall	Precision	图谱独有
CVE→CWE	has_weakness	NVD weaknesses + CVE problemTypes	43	45	43	100%	95.6%	2
CVE→CPE	affects_product	NVD configurations（每 CVE ≤4）	141	141	141	100%	100%	0
CWE→CAPEC	relates_to_pattern	CWE XML 4.20	50	50	50	100%	100%	0
CAPEC→ATT&CK	implemented_by	分析师 crosswalk（24 条）	23	23	23	100%	100%	0
Technique→Tactic	belongs_to_tactic	ATT&CK kill_chain_phases	37	40	37	100%	92.5%	3
Sigma→Technique	detects	Sigma 规则元数据	64	67	64	100%	95.5%	3
CVE→KEV	known_exploited	CISA KEV ∩ 切片	40	40	40	100%	100%	0

> **口径说明**：Recall=100% 是本切片“结构化通道完整导入官方映射”的构造结果，不是抽取能力的证据。跨源核验的意义在于：(a) 验证 ID 归一化没有破坏官方映射；(b) 量化正文抽取带来的额外边（Precision 缺口）；(c) 提供可逐条复核的抽样。

KEV 覆盖：KEV 清单 1754 条，切片内 40 条 CVE 全部在图中有 ExploitationRecord 节点和 known_exploited 边，覆盖 40/40；图谱中没有切片外的 KEV 边（kg_only_count = 0）。抽样表见 data/reports/t2-cve-attack_cross_source.md。

CAPEC→ATT&CK 的诚实标注：MITRE 并未发布官方 CAPEC→ATT&CK 映射，本作业使用 topics/t2-cve-attack/capec_attck_crosswalk.csv（24 条人工映射，CC BY 4.0，标注 high/medium confidence），在报告与代码注释中都明确写成“分析师 crosswalk”，不冒充官方标准。

6 阶段三：KG 增强 Agent

6.1 链路

```
问题 → 实体链接（最长匹配 + 占位去重）→ 子图检索（BFS ≤4 跳）
     → 三元组上下文 + 编号 → LLM 生成（只许用给定三元组）
     → 逐句核验（编号/引用/证据）→ 三级溯源 → 答案
```

- **检索**：按“路径边 3.0 > 种子间边 2.5 > 种子直接边 2.0 > 候选集边 1.0”排序，排除 mentioned_in 与 Document 节点（否则任意两实体 2 跳可达，路径失去意义）；
- **生成**：只给检索到的三元组和编号，要求每个结论后标 [n]，缺信息时输出固定拒答句；
- **核验**：句中每个官方编号必须是检索三元组的端点；[n] 必须有效且与被引三元组相关（防止“随便挂一个引用”）；没有编号的句子必须能通过回指上下文与引用锚定，否则计为不可溯源。对“图谱未给出更具体版本”这类关于检索结果本身的陈述单列为 meta，不计入幻觉分母，也不冒充 supported。

6.2 题库与结果

12 道题：6 道单跳、4 道多跳（q06–q09）、2 道应拒答（q11 不存在的 CVE、q12 图谱中不存在的产品）。期望三元组共 27 条。

指标	KG 增强	无图谱基线
检索覆盖	27/27（100%）	—
答案实体覆盖	27/27（100%）	13/27（48.15%）
拒答正确	2/2	2/2
计入核验的句子	19	12
可溯源句	19	5
不可溯源句	**0**	**7**
幻觉率	**0%**	**58.33%**
未落地编号	0	8 个（CAPEC-108、CAPEC-248、CAPEC-88、T1053.005、T1059.005、T1106、T1204.002、T1569.002）

幻觉率下降 58.33 个百分点。基线在同样的 12 道题上凭模型记忆作答，编造了图谱中不存在的 CAPEC/ATT&CK 编号；KG 增强路径因为只允许使用检索三元组，且逐句核验，全部句子可溯源。

6.2.1 LLM 单方法图 vs 融合图（验收点）

用方法 C 的 985 条三元组单独建一张旁路图（801 节点），跑同一套题、同一验证器：

指标	LLM 单方法图	融合图	无图谱基线
检索覆盖	27/27（100%）	27/27（100%）	—
答案覆盖	27/27（100%）	27/27（100%）	13/27（48.15%）
可溯源句	19/19	19/19	5/12
不可溯源句	0	0	7
幻觉率	**0%**	**0%**	**58.33%**

两图在本题库上都没有不可溯源句，出现**地板效应**：题库涉及的事实两套图都能检索到，生成端因此没有机会编造。差异不在幻觉率，而在图的结构：LLM 单方法图 801 节点 /985 边（含重复边），融合图 421 节点 / 1572 边（去重后补回 KEV、CPE、战术等结构化关系）。若要让该指标拉开差距，需要加入只在某一路图谱中覆盖的问题；本作业按同一题库口径如实报告 0% vs 0%，不把地板效应包装成融合优势。

6.3 三级溯源

每条答案句都给出：

1. **句子级**：该句引用了哪些三元组编号；
2. **三元组级**：头/关系/尾、置信度、命中方法、原文证据；
3. **文档/来源级**：doc → sources.yaml 的来源名称与许可证。

例如 q08 的答案 “CVE-2018-13379 影响 FortiProxy 2.0.0 [2]” 可追溯到 cve:CVE-2018-13379 --affects_product--> cpe:2.3:a:fortinet:fortiproxy:2.0.0:…，再到 cve_records_01，再到 NVD/CVE 与对应许可证。

6.4 MCP 接入

kgc/mcp_server.py 以 stdio 暴露 4 个工具：kg_stats、kg_search、 kg_neighbors（带证据）、kg_path（默认排除文档枢纽）。冒烟测试 scripts/mcp_smoke_client.py --topic t2-cve-attack 全部通过：

- initialize / tools/list schema 完整；
- kg_search("CVE-2021-44228") 命中 2 个节点；
- kg_neighbors("T1059.001", relation="belongs_to_tactic") 返回 1 条带证据三元组；
- kg_path("G0096","TA0002") 返回 G0096 → T1059.001 → TA0002；
- 不存在的路径返回 found=false，Agent 应据此拒答。

Skill 说明见 skills/kg-qa/SKILL.md，其中给出题目二的 search/neighbors/path/ask 示例和 agent_t2 verify 自检命令。

7 复现与仓库结构

7.1 一条命令

Windows：

```
scripts\run_t2.cmd
```

脚本依次执行：抓数（首次）→ 词典 → 语料 → 本体与自检 → 方法 A/B/C →金标准与自检 → 融合 → 建图 → 评测 → 跨源核验 → 问答评测 → MCP 冒烟 → 脚手架自检；任何一步非零退出立即停止，不吞错。

Linux/macOS 等价命令（把解释器换为 .venv/bin/python）：

```
python scripts/fetch_t2_data.py
python scripts/lexicon_build.py && python scripts/corpus_build.py
python -m kgc.ontology --topic t2-cve-attack && python -m kgc.ontology --topic t2-cve-attack --check
python -m kgc.rule_a --topic t2-cve-attack
python -m kgc.model_t2 --topic t2-cve-attack
python -m kgc.llm_t2 --topic t2-cve-attack
python scripts/build_gold.py && python scripts/check_gold.py --topic t2-cve-attack
python -m kgc.fuse --topic t2-cve-attack && python -m kgc.kg --topic t2-cve-attack
python -m kgc.evaluate --topic t2-cve-attack
python scripts/cross_source_report.py
python -m kgc.agent_t2 --topic t2-cve-attack bench
python scripts/compare_single_vs_fusion.py --topic t2-cve-attack
python scripts/mcp_smoke_client.py --topic t2-cve-attack
KGC_TOPIC=t2-cve-attack python tests/test_pipeline.py
```

方法 C 需要 KGC_LLM_API_KEY（或 ANTHROPIC_AUTH_TOKEN）；已有 data/llm_cache/ 时可离线复用缓存。首次抓取原始数据需要外网。

7.2 目录

```
kgc/                    本体、抽取、融合、建图、评测、Agent、MCP
scripts/                fetch_t2_data / lexicon_build / corpus_build / build_gold /
                        cross_source_report / mcp_smoke_client / run_t2.cmd
topics/t2-cve-attack/ ontology.json、patterns.yaml、topic.yaml、sources.yaml、
                        lexicons.yaml、gold.jsonl、capec_attck_crosswalk.csv
data/                   corpus、extraction、kg、ontology、reports、qa（raw 不入库）
skills/kg-qa/           KG 问答 Skill
tools/check_restricted_data.py  提交前数据门禁
tests/test_pipeline.py          全链路自检（KGC_TOPIC 指定选题）
```

7.3 自检结果

检查	结果
本体自检	ok=true，0 问题
金标准自检	1171 行全部 OK
脚手架测试（KGC_TOPIC=t2-cve-attack）	5/5 通过
MCP 冒烟	全部通过
受限数据门禁	高风险 0，中/低 0，通过

8 局限与改进

1. 方法 B 的结构性关系缺口：三元组召回 48.6%，因为 produced_by、known_exploited 等关系在语料中没有自然语言触发句。可改进方向是把结构化字段也渲染成“可学习”的句子，或引入跨句关系分类；但这会改变“从文本抽”的方法定义，本作业选择保留缺口并在报告中量化。

2. 文档级交叉验证的冷启动：5 折按文档划分，测试折中的实体/触发词可能从未在训练折出现，导致召回偏低；这比随机句子划分更严格，也更接近真实部署。

3. 金标准与结构化通道同源：A 的高分是数据通道优势，不能当作抽取能力；B/C 的对比才是方法层面的比较。报告已在 §4.1 明确口径。

4. CAPEC→ATT&CK 是分析师映射：24 条人工 crosswalk，不是 MITRE 官方标准；置信度已标注，抽样可复核。

5. CPE 切片口径：每 CVE 最多 4 条 CPE，跨源覆盖率的分母也按同一切片计算；不能外推为“NVD 全量 CPE 的覆盖率”。

6. LLM 非确定性：temperature=0 仍可能因服务端版本变化产生差异；所有调用有缓存，评测可复现到缓存版本。

7. 仓库与可复现性：代码与产物已推送至个人仓库 https://github.com/sxy-Cindy/network-kg-t2（main 分支）；.gitignore 排除 data/raw/、data/llm_cache/ 与 .venv/，首次复现需联网抓数与重新调用 LLM （或使用本地缓存）。

9 附录：产物索引

产物	路径
本体 TTL / JSON	data/ontology/t2-cve-attack_ontology.{ttl,json}
本体自检	data/reports/t2-cve-attack_ontology_check.json
三方法抽取	data/extraction/t2-cve-attack_{rule,model,llm,ensemble}.json
图谱 JSON/TTL/GraphML/Cytoscape	data/kg/t2-cve-attack_kg.*
抽取评测	data/reports/t2-cve-attack_eval.{json,md}
跨源核验	data/reports/t2-cve-attack_cross_source.{json,md}
问答评测	data/reports/t2-cve-attack_qa_bench.{json,md}
LLM 单方法 vs 融合	data/reports/t2-cve-attack_single_vs_fusion.{json,md}、*_qa_bench_llm_single.*
逐题答案与溯源	data/qa/t2-cve-attack_answers.jsonl
数据源/许可证映射	topics/t2-cve-attack/sources.yaml
金标准与人工抽检	topics/t2-cve-attack/gold.jsonl、gold_sample.jsonl